TuWa

admin@tuwa.io

Політика безпеки

Останнє оновлення: 28 жовтня 2026 р.

Ця Політика безпеки пояснює, як повідомити про вразливість безпеки в екосистемі TUWA, чого ви можете очікувати від ФОП Ткача Олександра («ми», «нас» або «наш»), коли це зробите, і хто за що відповідає. Вона охоплює наші npm-пакети з відкритим кодом, Quasar Cloud, Quasar Community Edition і Quasar Payments. Ми вітаємо повідомлення від дослідників безпеки та користувачів і не вживатимемо правових заходів щодо досліджень, проведених добросовісно відповідно до цієї політики (розділ 5).

1. Що ми обіцяємо і чого не обіцяємо

- **Ми обіцяємо** відповідати на повідомлення в строки, зазначені в розділі 6, інформувати вас, доки проблему не буде усунуто, не переслідувати за добросовісні дослідження (розділ 5) і публічно подякувати вам, якщо ви цього бажаєте.
- **Ми не обіцяємо**, що наше програмне забезпечення чи сервіси не мають вразливостей, що ми виплачуємо винагороди (програми bug bounty немає, див. розділ 7) або що ми виправляємо версії, які більше не підтримуються (розділ 2).

2. Сфера дії

Входить до сфери дії:

- Останні опубліковані версії наших npm-пакетів (`@tuwaio/*`).
- Quasar Cloud: api.tuwa.io і панель керування за адресою quasar.tuwa.io.
- Код Quasar Community Edition, остання мінорна версія.

- Quasar Payments — з моменту його випуску: платіжна частина Quasar Engine, API оформлення платежу (checkout) і токени оформлення платежу, розміщена нами платіжна сторінка (`/pay`), ретранслятор (relayer) EIP-3009, проксі paymaster ERC-7677, колектор автоматичних списань ERC-7715, вебхуки `payments.v1` і `verifyWebhook`, реєстр платежів і видані документи, `@tuwaio/nova-payments` та `@tuwaio/quasar-sdk/checkout`.

Приклади, які завжди входять до сфери дії: доступ до застосунків, транзакцій або ключів іншої організації; підроблений або повторно відтворений підпис вебхука; пакет, який розкриває ключ або підписує те, чого користувач не підтверджував. З моменту випуску Quasar Payments також: платіж, зарахований в оплату іншого рахунку або від іншого платника; змінені сума, актив, мережа чи одержувач у котируванні (quote); обхід AML-перевірки; доступ до рахунку, виставленого іншій особі, через його токен або шляхом підбору; зміна в реєстрі платежів або в документі, яку не виявляє перевірка ланцюжка хешів; списання понад ліміт або поза періодом дозволу гаманця; ретранслятор чи paymaster, який оплачує газ за виклики іншої особи.

Не входить до сфери дії:

- Інсталяції Quasar Community Edition, якими керують інші особи: будь ласка, повідомляйте їхньому оператору (вразливість у коді самої Community Edition входить до сфери дії).
- Сторонні сервіси, зокрема гаманці, постачальники RPC, WalletConnect, GoPlus, Chainalysis, Pimlico та інші paymaster-сервіси, Gelato і Resend. Будь ласка, повідомляйте їм безпосередньо.
- Зміст санкційних списків, як-от списку OFAC.
- Повідомлення без продемонстрованого впливу, як-от відсутні заголовки безпеки, банери з версіями або відсутність обмежень частоти запитів на нечутливих сторінках.
- Соціальна інженерія та фізичний доступ.

3. Як повідомити

Напишіть на security@tuwa.io і вкажіть:

- пакет і версію або сервіс і маршрут, яких це стосується;
- кроки для відтворення або доказ концепції (proof of concept);
- вплив, який, на вашу думку, має вразливість.

Будь ласка, не розголошуйте вразливість публічно, доки її не буде виправлено, до дати розкриття, про яку ми домовилися, або, якщо ми не змогли домовитися, доки не спливе строк письмового повідомлення, передбачений розділом 6. Будь ласка, не надсилайте нам персональних даних інших осіб понад те, що потрібно, щоб продемонструвати проблему.

4. Правила тестування

- Тестуйте лише з власними обліковими записами й застосунками, у тестовому режимі та в тестових мережах. Якщо вразливість неможливо продемонструвати там, повідомте про ймовірну проблему, не проводячи недозволеного тестування в робочому середовищі.
- Не отримуйте доступу до коштів чи даних, які вам не належать, не змінюйте й не переміщуйте їх. Якщо ви випадково отримали до них доступ, зупиніться, повідомте нас і видаліть те, що ви отримали.
- Жодного навантажувального тестування, атак на відмову в обслуговуванні, спаму чи автоматизованого сканування понад ліміти частоти запитів API.
- Жодної соціальної інженерії чи фішингу щодо нашої команди, наших користувачів або наших постачальників.
- Дотримуйтеся законів, які застосовуються до вас.

5. Безпечна гавань

Якщо ви добросовісно докладаєте зусиль, щоб дотримуватися цієї політики, ми вважаємо ваше дослідження дозволеним щодо систем, якими ми володіємо та які контролюємо, у межах, визначених розділами 2 і 4. Ми співпрацюватимемо з вами, щоб зрозуміти та усунути проблему, і не вживатимемо правових заходів і не повідомлятимемо про вас правоохоронним органам у зв'язку з цим дослідженням. Якщо третя особа вживе проти вас правових заходів у зв'язку з дослідженням, яке відповідало цій політиці, ми доведемо до відома, що ваше дослідження було нами дозволене. Цей захист не поширюється на дії, що порушують правила розділу 4, або на системи, які нам не належать; ми не можемо дозволити діяльність у системах третіх осіб.

6. Як ми реагуємо

- **Підтвердження отримання:** протягом 3 робочих днів.

- **Оцінка:** протягом 7 робочих днів, із нашою позицією щодо рівня критичності.
- **Оновлення:** щонайменше кожні 14 днів, доки проблему не буде усунуто.
- **Цільові строки виправлення** залежно від рівня критичності за CVSS 4.0: критичний — 7 днів, високий — 30 днів, середній — 90 днів, низький — за можливості. Будь-яка загроза коштам вважається критичною.
- **Розкриття:** ми прагнемо узгоджувати з вами розкриття після виправлення. Якщо ризик для користувачів вимагає дій до виправлення, ми можемо домовитися з вами про раніший бюлетень безпеки, у якому описано ризик і кроки, яких можуть вжити користувачі. Якщо проблема залишається неусуненою через 90 днів після повідомлення, ми обговоримо з вами дату розкриття та кроки щодо зменшення ризику; якщо ми не зможемо домовитися, кожен із нас може здійснити публікацію, письмово повідомивши іншу сторону за 30 днів, без подробиць, які дали б змогу іншим скористатися вразливістю. Для наших пакетів і Quasar Community Edition ми публікуємо GitHub Security Advisory і, за потреби, запитуємо CVE. За вашим бажанням ми зазначаємо вас як автора виявлення в бюлетені.

7. Винагороди

Ця політика не обіцяє винагород, і ми не проводимо програми винагород за виявлення вразливостей (bug bounty). Якщо ми її запустимо, вона матиме власні умови із зазначенням сум. Будь-яку винагороду було б виплачено лише за повідомлення, що відповідають цій політиці, і в жодному разі не особам, щодо яких застосовано санкції, а одержувач самостійно відповідає за сплату своїх податків.

8. Розподіл відповідальності

- **Ми** відповідаємо за код наших пакетів і Quasar Community Edition, а також за експлуатацію Quasar Cloud.
- **Клієнти Quasar Cloud** відповідають за свої ключі API, секрети вебхуків, налаштовані ними ключі постачальників і кінцеві точки RPC, а також за доступ учасників своїх команд; з моменту випуску Quasar Payments — також за свої адреси одержувачів, налаштування AML і безгазових транзакцій (gasless).

- **Оператори Quasar Community Edition** відповідають за своє розгортання, оновлення, секрети, постачальників RPC, резервні копії та інфраструктуру.
- **Покупці та користувачі** відповідають за свої гаманці й ключі, а також за перевірку того, що вони підписують.
- **Сторонні сервіси** відповідають за власну безпеку.

TUWA працює за некастодіальною моделлю: ми ніколи не зберігаємо ваших приватних ключів чи коштів і не можемо скасувати транзакцію в блокчейні.

9. Що ми робимо для забезпечення безпеки

Ми підтримуємо залежності в актуальному стані, публікуємо npm-релізи з підтвердженням походження (provenance), вимагаємо двофакторної автентифікації та доступу за принципом найменших привілеїв у нашій організації, шифруємо збережені секрети, ведемо для Quasar Payments реєстр, до якого записи лише додаються і в якому вони пов'язані ланцюжком хешів, відстежуємо роботу наших сервісів і показуємо їхній стан на tuwa.io/status, а також дотримуємося плану реагування на інциденти. Тут описано нашу практику; це не є гарантією.

10. Повідомлення про інциденти

Якщо інцидент безпеки зачіпає клієнтів Quasar Cloud, ми повідомляємо їх без невиправданої затримки. У разі порушення безпеки персональних даних ми повідомляємо наглядовий орган і осіб, яких це стосується, як того вимагає законодавство про захист даних. Відповідно до GDPR, якщо повідомлення наглядового органу є обов'язковим, його слід здійснити без невиправданої затримки і, якщо це можливо, не пізніше ніж через 72 години після того, як стало відомо про порушення; повідомлення фізичних осіб є обов'язковим без невиправданої затримки, якщо порушення, імовірно, призведе до високого ризику для їхніх прав і свобод, з урахуванням винятків, передбачених законом (Регламент (ЄС) 2016/679, статті 33 і 34). Інформація про збої в роботі відображається на tuwa.io/status.

11. Застереження

Ця політика не є договором і не є гарантією. Наше програмне забезпечення надається «як є» відповідно до його ліцензії (Apache-2.0 для наших пакетів і Quasar Community Edition, MIT-0 для стартових шаблонів). Обмеження відповідальності та застосовне право визначено в наших Умовах надання послуг. Ми можемо змінювати цю політику; дату чинної редакції зазначено вгорі.

12. Контакти

Повідомляйте про вразливості на security@tuwa.io. З інших питань щодо цієї політики звертайтеся до нас за адресою admin@tuwa.io.